Security controls - OrdinCore

Describes OrdinCore's security controls as they exist in the code and infrastructure, with references to the actual files, and is honest about gaps. Intended to be shareable with customers' information-governance teams. Not a certification; where an external certification is referenced it is marked as a gap.

Summary

OrdinCore is a multi-tenant SaaS processing health/social-care data. Security is enforced primarily in the API layer (every request is authenticated, tenant-scoped and role-checked) and the database (tenant columns on every record, least-privilege DB role). The main gaps today are MFA (in progress), append-only audit logging (in progress), and Cyber Essentials certification (not held). Each is marked below.

1. Tenant isolation (multi-tenancy)

- Every tenant-scoped request passes requireTenant (backend/src/middleware/tenant.middleware.ts (../../backend/src/middleware/tenant.middleware.ts)), which pins the caller's company_id. Queries are always scoped WHERE company_id = $1, so one provider can never read another's data.
- Verified by the C-04 tenant-isolation test suite (see DPIA §6 R1).
- Status: [OK] Strong (code-enforced + tested).

2. Authentication

- JWT bearer tokens, verified on every request by requireAuth (backend/src/middleware/auth.middleware.ts (../../backend/src/middleware/auth.middleware.ts)).
- Login and token issuance in backend/src/services/auth.service.ts (../../backend/src/services/auth.service.ts) / backend/src/controllers/auth.controller.ts (../../backend/src/controllers/auth.controller.ts).
- Password hashing: bcrypt (one-way, salted) - passwords are never stored or logged in plaintext.
- 45-day password expiry is enforced (users are routed to reset on expiry).
- Status: [OK] for password auth. [IN PROGRESS] MFA: in progress (TOTP being implemented; will be mandatory for Admin/Super-Admin and Registered-Manager-and-above, and when a company enables it for all).

3. Authorisation - RBAC and scope (least privilege)

- Role-based access: requireRole(...) (backend/src/middleware/role.middleware.ts (../../backend/src/middleware/role.middleware.ts)) gates each route to the roles permitted (SUPPORT_WORKER, TEAM_LEADER, REGISTERED_MANAGER, DIRECTOR, RESPONSIBLE_INDIVIDUAL, ADMIN, SUPER_ADMIN).
- House/service scope: requireScope (backend/src/middleware/scope.middleware.ts (../../backend/src/middleware/scope.middleware.ts)) restricts operational roles to their assigned houses - staff only see data for services they are

assigned to.
- Status: [OK] Strong. Gap: a written access-control/least-privilege policy + periodic access review record - see policies/access-control-and-least-privilege.md (./policies/access-control-and-least-privilege.md).

4. Rate limiting & brute-force protection

- Login and auth routes are rate-limited and slowed (backend/src/middleware/rateLimit.middleware.ts (../../backend/src/middleware/rateLimit.middleware.ts)
- loginRateLimit, loginSlowDown, authRouteLimit); contact/other sensitive routes also limited.
- Security events (e.g. failed logins) are logged via logSecurityEvent.
- Status: [OK]. MFA attempts will be rate-limited and audit-logged when MFA ships.

5. HTTP security headers

- helmet configured in backend/src/app.ts (../../backend/src/app.ts) (CSP, HSTS and related headers). Status: [OK].

6. Transport security (TLS)

- All web/API traffic served over HTTPS (cPanel AutoSSL / Let's Encrypt).
- Outbound email verifies TLS certificates by default; disabling it logs a loud warning (../operations/email-and-smtp.md (../operations/email-and-smtp.md)). Status: [OK] (email cert fix pending on the provider side).

7. Encryption at rest

- Database and server storage on the hosting platform. [CONFIRM] disk/volume encryption with the host (Krystal). MFA secrets (when added) will be encrypted at rest; recovery codes stored hashed.
- Status: [IN PROGRESS] - confirm host disk encryption and document it.

8. Audit logging

- Security-relevant actions are written to the audit_logs table (who, what, when, resource).
- See ../operations/audit-log-integrity.md (../operations/audit-log-integrity.md).
- Status: [IN PROGRESS] ? [OK] in progress: a migration makes audit_logs append-only (UPDATE/DELETE revoked from the application DB role) so logs cannot be quietly altered; retention ? 6 months.

9. Backups & continuity

- Automated backups, restore-tested (../operations/backup-and-restore.md (../operations/backup-and-restore.md)).
- v8 hardening: an independent/off-server backup copy is required (no cloud-sync-only). Gap tracked; see dspt-readiness.md (./dspt-readiness.md) §0.5 and the BCP policy.

10. Monitoring

- ../operations/monitoring-and-alerting.md (../operations/monitoring-and-alerting.md). Status: [OK].

11. Secure development

- Secrets never committed; gitleaks in CI + pre-commit hook (../operations/secret-management.md (../operations/secret-management.md)).
- Dependency vulnerability gate in CI + weekly Dependabot (../operations/dependency-audit-status.md (../operations/dependency-audit-status.md)).
- CI runs clean build, tests and migrations on every push (.github/workflows/ci.yml).
- v8: map practice to the UK Government *Software Security Code of Practice* - see policies/secure-development.md (./policies/secure-development.md). Status: [IN PROGRESS].

Known gaps (honest list)

Gap | Status | Where tracked

MFA (TOTP) | In progress | this doc §2; MFA build

Append-only audit logs | In progress | this doc §8; migration

Cyber Essentials / CE+ certification | Not held | dspt-readiness.md (./dspt-readiness.md) Std 9

Penetration test | Never run | dspt-answers.md (./dspt-answers.md) 9.2.1

Off-server/immutable backup copy | Outstanding | §9; backup runbook

EOL runtime (Node 20, PostgreSQL 13) | Outstanding | asset-register.md (./asset-register.md)

Host disk encryption confirmation | To confirm | §7